

재단법인 행복ICT

개인정보 내부관리 계획서

2022년 08월 09일



목 차

제1장. 총 칙	4
제2장. 내부관리계획 수립 및 시행	5
제3장. 개인정보 보호책임자의 역할 및 책임.....	5
제4장. 개인정보 보호 교육	6
제5장. 기술적 안전조치.....	7
제6장. 관리적 안전조치.....	8
제7장. 물리적 안전조치.....	9
제8장. 그 밖에 개인정보 보호를 위하여 필요한 사항.....	7

제·개정 이력

[illegible]

제1장 총칙

제1조(목적)

개인정보 내부관리계획(이하 ‘본 계획’ 또는 ‘내부관리계획’이라 한다)은 개인정보보호법 및 정보통신망 이용촉진 및 정보보호 등에 관한 법률의 내부관리계획의 수립 및 시행 의무에 따라 제정된 것으로 (재)행복ICT(이하 ‘회사’라 한다)가 처리하는 개인정보를 체계적으로 관리하여 개인정보가 분실, 도난, 유출, 위조, 변조, 훼손, 오·남용 등이 되지 아니하도록 함을 목적으로 한다.

제2조(용어 정의)

본 계획에서 사용하는 용어의 정의는 다음 각 호와 같다.

1. “정보주체”란 처리되는 정보에 의하여 알아볼 수 있는 사람으로서 그 정보의 주체가 되는 사람을 말한다.
2. “개인정보”라 함은 생존하는 개인에 관한 정보로서 성명/주민등록번호 등에 의하여 특정한 개인을 알아볼 수 있는 부호/문자/음성/음향 및 영상 등의 정보(해당 정보만으로 특정 개인을 알아볼 수 없어도 다른 정보와 쉽게 결합하여 알아볼 수 있는 경우에는 그 정보를 포함한다)를 말한다.
3. “개인정보 보호책임자”라 개인정보 처리에 관한 업무를 총괄해서 책임지거나 업무처리를 최종적으로 결정하는 자를 말한다.
4. “개인정보 보호담당자”라 함은 기관 내 개인정보보호 업무 및 업무처리를 담당하는 자를 말한다.
5. “개인정보취급자”라 함은 개인정보를 처리하는 업무를 담당하는 자로서 직접 개인정보에 관한 업무를 담당하는 자와 그 밖에 업무상 필요에 의해 개인정보에 접근하여 처리하는 모든 자를 말한다.
6. “개인정보처리시스템”이라 함은 개인정보를 처리할 수 있도록 체계적으로 구성한 시스템을 말한다.
7. “비밀번호”란 정보주체 또는 개인정보취급자 등이 개인정보처리시스템, 업무용 컴퓨터 또는 정보통신망 등에 접속할 때 식별자와 함께 입력하여 정당한 접속 권한을 가진 자라는 것을 식별할 수 있도록 시스템에 전달해야 하는 고유의 문자열로서 타인에게 공개되지 않는 정보를 말한다.
8. “정보통신망”이란 「전기통신기본법」 제2조제2호에 따른 전기통신설비를 이용하거나 전기통신설비와 컴퓨터 및 컴퓨터의 이용기술을 활용하여 정보를 수집, 가공, 저장, 검색, 송신 또는 수신하는 정보통신체계를 말한다.
9. “바이오정보”란 지문, 얼굴, 홍채, 정맥, 음성, 필적 등 개인을 식별할 수 있는 신체적 또는 행동적 특징에 관한 정보로서 그로부터 가공되거나 생성된 정보를 포함한다.
10. “보조저장매체”란 이동형 하드디스크, USB메모리, CD(Compact Disk), DVD(DigitalVersatile Disk) 등 자료를 저장할 수 있는 매체로서 개인정보처리시스템 또는 개인용 컴퓨터 등과 용이하게 연결, 분리할 수 있는 저장매체를 말한다.
11. “접속기록”이란 개인정보취급자 등이 개인정보처리시스템에 접속하여 수행한 업무내역에 대하여 개인정보취급자 등의 계정, 접속일시, 접속지 정보, 처리한 정보주체정보, 수행업무 등을 전자적으로 기록한 것을 말한다. 이 경우 “접속”이란 개인정보처리시스템과 연결되어 데이터 송신 또는 수신이 가능한 상태를 말한다.
12. “관리용 단말기”란 개인정보처리시스템의 관리, 운영, 개발, 보안 등의 목적으로 개인정보

처리시스템에 직접 접속하는 단말기를 말한다.

제3조(적용 범위)

본 계획은 회사 내에서 고객의 개인정보를 수집, 보관, 처리, 이용, 제공, 관리 또는 파기 등의 업무를 하는 '개인정보취급자'에게 적용된다

제2장 내부관리계획의 수립 및 시행

제4조(내부관리계획의 수립 및 승인)

- ① 개인정보 보호담당자는 회사의 개인정보보호를 위한 전반적인 사항을 포함하여 내부관리계획을 수립하여야 한다.
- ② 개인정보 보호담당자는 개인정보보호를 위한 내부관리계획의 수립시 개인정보보호와 관련한 법령 및 관련 규정을 준수하도록 내부관리계획을 수립하여야 한다.
- ③ 개인정보 보호책임자는 개인정보 보호담당자가 수립한 내부관리계획의 타당성을 검토하여 개인정보보호를 위한 내부관리계획을 승인하여야 한다.
- ④ 개인정보 보호담당자는 개인정보보호 관련 법령의 제·개정 사항 등을 반영하기 위하여 매년 내부관리계획의 타당성과 개정 필요성을 검토하여야 한다.
- ⑤ 개인정보 보호담당자는 모든 항목의 타당성을 검토한 후 개정할 필요가 있다고 판단되는 경우 12월말까지 내부관리계획의 개정안을 작성하여 개인정보 보호책임자에게 보고하고 개인정보 보호책임자의 승인을 받아야 한다.

제5조(내부관리계획의 공표)

- ① 개인정보 보호담당자는 前 조에 따라 승인한 내부관리계획을 매년 1월말까지 회사 전 임직원에게 공표한다.
- ② 내부관리계획은 임직원이 언제든지 열람할 수 있는 방법으로 비치하여야 하며, 변경사항이 있는 경우에는 이를 공지하여야 한다.

제3장 개인정보 보호책임자의 역할 및 책임

제6조(개인정보 보호책임자 및 개인정보 보호담당자의 지정)

회사의 개인정보 보호책임자는 및 개인정보 보호담당자는 다음과 같이 임명한다.

직책	성명	비고
개인정보 보호책임자	김완주	Delivery혁신센터 본부장
개인정보 보호담당자	유민경	경영지원팀 팀장

제7조(개인정보 보호책임자의 역할 및 책임)

- ① 개인정보 보호책임자는 고객의 개인정보보호를 위하여 다음 각 호의 임무를 수행한다.

1. 개인정보 보호담당자 및 취급자의 의무와 책임의 규정 및 총괄관리
 2. 내부관리계획의 수립 및 승인
 3. 개인정보의 안전성 확보조치 기준 이행 총괄
 4. 임직원 또는 제3자에 의한 위법·부당한 개인정보 침해행위에 대한 점검, 대응, 사후조치 총괄
 5. 고객으로부터 제기되는 개인정보에 관한 고충이나 의견의 처리 및 감독 총괄
 6. 임직원 및 개인정보취급업무 수탁자 등에 대한 교육 총괄
 7. 본 계획에 규정된 개인정보보호와 관련된 제반 조치의 시행 총괄
 8. 기타 고객의 개인정보보호에 필요한 사항
- ② 개인정보 보호책임자는 개인정보취급자를 최소한으로 제한하여 지정하고 수시로 관리·감독하여야 하며, 임직원에 대한 교육 및 보안서약 등을 통해 개인정보 침해사고를 사전에 예방한다.
- ③ 개인정보 보호책임자는 개인정보 관련 업무의 효율적 운영을 위하여 개인정보 관리 전담부서의 직원 중 1인 이상을 개인정보 보호담당자로 임명한다.
- ④ 개인정보 보호담당자는 개인정보 보호책임자를 보좌하여 개인정보보호 업무에 대한 실무를 총괄하고 관리한다.

제8조(개인정보취급자의 범위 및 역할과 책임)

- ① 개인정보취급자의 범위는 회사 내에서 고객들의 개인정보 수집, 보관, 처리, 이용, 제공, 관리 또는 파기 등의 업무를 수행하는 자를 말하고, 정규직 이외에 임시직, 계약직 직원도 포함될 수 있다.
- ② 개인정보취급자는 고객의 개인정보보호와 관련하여 다음과 같은 역할 및 책임을 이행한다.
1. 개인정보보호 활동 참여
 2. 내부관리계획의 준수 및 이행
 3. 개인정보의 안전성 확보조치 기준 이행
 4. 업무상 알게 된 개인정보의 훼손·침해 또는 누설 금지
 5. 기타 고객의 개인정보보호를 위해 필요한 사항의 이행

제4장 개인정보 보호 교육

제9조(개인정보보호 교육 계획의 수립)

- ① 개인정보 보호책임자는 다음 각 호의 사항을 포함하는 연간 개인정보보호 교육계획을 매년 12월말까지 수립한다.
1. 교육목적 및 대상
 2. 교육내용
 3. 교육 일정 및 방법
- ② 개인정보 보호책임자는 수립한 개인정보보호 교육 계획을 실시한 이후에 교육의 성과와 개선 필요성을 검토하여 차년도 교육계획 수립에 반영하여야 한다.

제10조(개인정보보호 교육의 실시)

- ① 개인정보 보호책임자는 고객정보보호에 대한 직원들의 인식제고를 위해 노력해야 하며, 개인

정보의 오·남용 또는 유출 등을 적극 예방하기 위해 임·직원을 대상으로 매년 정기적으로 개인정보보호 교육을 실시한다.

- ② 교육 방법은 집체 교육뿐만 아니라, 인터넷 교육, 그룹웨어 교육 등 다양한 방법을 활용하여 실시하고, 필요한 경우 외부 전문기관이나 전문요원에 위탁하여 교육을 실시할 수 있다.
- ③ 개인정보보호에 대한 중요한 전파 사례가 있거나 개인정보보호 업무와 관련하여 변경된 사항이 있는 경우, 개인정보 보호책임자는 부서 회의 등을 통해 수시 교육을 실시할 수 있다.

제5장 기술적 안전조치

제11조(접근권한의 관리)

- ① 개인정보 보호책임자는 개인정보처리시스템에 대한 접근권한을 업무 수행에 필요한 최소한의 범위로 업무 담당자에 따라 차등 부여한다.
- ② 개인정보 보호책임자는 전보 또는 퇴직 등 인사이동이 발생하여 개인정보취급자가 변경되었을 경우 지체 없이 개인정보처리시스템의 접근권한을 변경 또는 말소하여야 한다.
- ③ 개인정보 보호책임자는 제1항 및 제2항에 의한 권한 부여, 변경 또는 말소에 대한 내역을 기록하고, 그 기록을 최소 5년간 보관하여야 한다.
- ④ 개인정보 보호책임자는 개인정보처리시스템에 접속할 수 있는 사용자 계정을 발급하는 경우, 개인정보취급자 별로 한 개의 사용자계정을 발급하여야 하며, 다른 개인정보취급자와 공유되지 않도록 하여야 한다.

제12조(접근통제)

- ① 개인정보 보호책임자는 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 다음 각 호의 기능을 포함한 시스템을 설치 및 운영한다.
 - 1. 개인정보처리시스템에 대한 접속 권한을 IP 주소 등으로 제한하여 인가 받지 않은 접근을 제한
 - 2. 개인정보처리시스템에 접속한 IP 주소 등을 재분석하여 불법적인 개인정보 유출 시도를 탐지
- ② 개인정보 보호책임자는 개인정보취급자가 생일, 주민등록번호, 전화번호 등 추측하기 쉬운 숫자나 개인관련 정보를 패스워드로 이용하지 않도록 비밀번호 작성규칙을 수립하고, 이를 적용 및 운용하여야 한다. 개인정보취급자는 개인정보 보호책임자가 수립한 비밀번호 작성규칙을 준수하여야 한다.
- ③ 개인정보 보호책임자는 처리중인 개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통해 열람권한이 없는 자에게 공개되지 않도록 개인정보처리시스템 및 개인정보취급자의 업무용 컴퓨터에 조치를 취하여야 한다.
- ④ 회사가 별도의 개인정보처리시스템을 이용하지 아니하고 업무용 컴퓨터만을 이용하여 개인정보를 처리하는 경우에는 제1항을 적용하지 아니할 수 있으며, 이 경우 업무용 컴퓨터의 운영체제나 보안프로그램 등에서 제공하는 접근통제 기능을 이용할 수 있다.

제13조(개인정보의 암호화)

- ① 개인정보 보호책임자는 고유식별정보(주민등록번호, 여권번호, 면허번호, 외국인등록번호), 신

용카드 번호 및 계좌번호, 바이오정보에 대해서는 안전한 암호 알고리즘으로 암호화하여 저장하여야 한다.

- ② 개인정보 보호책임자는 비밀번호는 복호화 되지 아니하도록 일방향 암호화 하여 저장하여야 한다.
- ③ 개인정보 보호책임자는 정보통신망을 통해 개인정보 및 인증정보를 송·수신하거나 보조저장매체 등을 통하여 전달하는 경우에는 이를 암호화하여야 한다.
- ④ 개인정보취급자는 고객의 개인정보를 개인용 컴퓨터(PC)에 저장할 때에는 이를 암호화해야 한다.

제14조(접속 기록의 보관 및 점검)

- ① 개인정보 보호책임자는 접속 기록의 위변조 방지를 위해 개인정보취급자가 개인정보처리 시스템에 접속하여 개인정보를 처리(입/출력, 수정, 등 DB접근)하는 경우에는 처리일시, 처리내역 등 접속기록을 저장한다.
- ② 개인정보 보호책임자는 제1항의 접속기록에 대해 월 1회 이상 정기적으로 확인·감독한다.
- ③ 개인정보 보호책임자는 제1항의 접속기록이 위·변조 및 도난, 분실되지 않도록 해당 접속기록을 안전하게 보관하여야 한다.

제15조(악성프로그램 등 방지)

- ① 개인정보 보호책임자는 악성프로그램 등을 방지·치료할 수 있는 백신 소프트웨어 등의 보안 프로그램을 설치·운영해야 한다
- ② 보안 프로그램은 항상 최신의 버전으로 업데이트를 적용하여야 한다.
- ③ 보안 프로그램의 최신 업데이트를 적용하기 위하여 자동 업데이트 설정 및 실시간 감시 기능을 적용하여야 한다.

제16조(관리용 단말기의 안전조치)

- ① 개인정보 보호책임자는 인가받지 않은 사람이 관리용 단말기에 접근하여 임의로 조작하지 못하도록 조치하여야 한다.
- ③ 개인정보보호 책임자는 관리용 단말기가 개인정보처리시스템의 관리, 운영, 개발, 보안 등 본래 목적 외로 사용되지 않도록 조치하여야 한다.
- ④ 관리용 단말기는 제13조에 따라 악성 프로그램 감염 방지 등을 위한 보안조치가 적용되어야 한다.

제6장 관리적 안전조치

제17조(개인정보 보호조직의 구성 및 운영)

- ① 개인정보 보호책임자는 개인정보 처리과정 전반에 걸쳐 개인정보를 안전하게 관리하고 보호하기 위하여 개인정보 보호조직을 구성하고 운영하여야 한다.
- ② 개인정보 보호조직은 처리하는 개인정보의 종류, 중요도 및 보유량, 개인정보를 처리하는 방

법 및 환경 등을 고려하여 구성 및 운영하여야 한다.

- ③ 개인정보 보호조직은 인사명령, 업무분장, 내부 관리계획 등에 명시하도록 하며 인력의 지정에 관한 사항, 역할 및 책임 그리고 역량 및 요건 등 적정성에 관한 사항 등을 포함할 수 있다.

제18조(개인정보 유출사고 대응)

- ① 개인정보 유출사고 발생 시 신속한 대응을 통해 피해 발생을 최소화하기 위하여 긴급조치, 유출 신고 및 통지, 피해신고 접수 및 피해 구제 등과 같은 사항을 포함하는 개인정보 유출사고 대응 계획을 수립 및 시행하여야 한다.

제19조(위험도 분석 및 대응)

- ① 개인정보 보호책임자는 100만명 이상의 개인정보 처리 및 보유시 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 위험도 분석을 수행하고 필요한 보안조치 적용 등 대응방안을 마련하여야 한다.
- ② 제1항에 따른 위험도 분석은 개인정보 위험도 분석 기준을 활용하거나 위험요소를 식별 및 평가하는 등의 방법으로 수행할 수 있다.

제20조(수탁자에 대한 관리 및 감독)

- ① 개인정보 처리업무 위탁으로 인하여 정보주체의 개인정보가 분실·도난·유출·변조 또는 훼손되지 아니하도록 수탁자를 교육하고, 수탁자가 개인정보를 안전하게 처리하는지를 감독하여야 한다.
- ② 수탁자에 대하여 정기적으로 교육을 실시하고, 수탁자의 개인정보 처리 현황 및 실태, 목적 외 이용·제공, 재위탁 여부, 안전성 확보조치 여부 등을 정기적으로 점검 등 관리·감독 하여야 한다.
- ③ 수탁자에 대한 교육 및 감독의 시기와 방법, 절차, 점검 항목 등을 수립하며, 이외 수탁자 교육 및 감독에 대한 기록을 남기고 문제점이 발견된 경우 그에 따른 개선 조치를 하여야 한다.

제7장 물리적 안전조치

제21조(물리적 안전조치)

- ① 개인정보 보호책임자는 개인정보와 개인정보처리시스템의 안전한 보관을 위한 물리적 잠금장치 등의 물리적 접근방지를 위한 보호조치를 취하여야 한다.
- ② 개인정보 보호책임자는 물리적 접근방지를 위한 별도의 보호시설에 출입하거나 개인정보를 열람하는 경우, 그 출입자에 대한 출입사실 및 열람 내용에 관한 관리대장을 작성하도록 하여야 한다.
- ③ 개인정보 보호책임자는 물리적 접근제한 관리대장의 출입 및 열람 내용을 주기적으로 검토하여 정당하지 않은 권한으로 출입하거나 열람하는 경우가 있는지를 점검하여 확인하여야 한다.
- ④ 개인정보 보호책임자는 개인정보가 포함된 서류, 보조저장매체 등을 잠금장치가 있는 안전한 장소에 보관하여야 한다.
- ⑤ 개인정보 보호책임자는 개인정보가 포함된 보조저장매체의 반출·입 통제를 위한 보안대책을 마련하여야 한다.

제22조(재해 및 재난 대비 안전조치)

- ① 개인정보 보호책임자는 100만명 이상의 개인정보 처리 및 보유시 화재, 홍수, 단전 등의 재해. 재난 발생 시 개인정보처리시스템 보호를 위한 위기대응 매뉴얼 등 대응절차를 마련하고 정기적으로 점검 및 백업 및 복구를 위한 계획을 마련하여야 한다.

제23조(개인정보의 파기)

- ① 개인정보 보호책임자는 개인정보를 파기할 경우 다음 각 호 중 어느 하나의 조치를 하여야 한다.
1. 완전파괴(소각, 파쇄 등)
 2. 전용 소자장비를 이용하여 삭제
 3. 데이터가 복원되지 않도록 초기화 또는 덮어쓰기 수행
- ② 개인정보보호책임자는 개인정보의 일부만을 파기하는 경우, 제1항의 방법으로 파기하는 것이 어려울 때에는 다음 각 호의 조치를 하여야 한다.
1. 전자적 파일 형태인 경우 : 개인정보를 삭제한 후 복구 및 재생되지 않도록 관리 및 감독
 2. 제1호 외의 기록물, 인쇄물, 서면, 그 밖의 기록매체인 경우 : 해당 부분을 마스킹, 천공 등으로 삭제

제8장 그 밖에 개인정보 보호를 위하여 필요한 사항

제24조(개인정보 관리현황 점검 및 평가)

- ① 개인정보 보호책임자는 개인정보보호를 위한 내부관리 계획 및 관련 법령에서 정하는 개인정보보호 규정을 성실히 이행하는지를 주기적으로 감사 또는 점검하여야 한다.
- ② 개인정보 보호책임자는 개인정보 자체감사를 위한 감사대상, 감사절차 및 방법 등 감사의 실시에 관하여 필요한 별도의 계획을 수립할 수 있다.
- ③ 개인정보보호 자체감사는 년 1회 이상 실시한다.

제25조(개인정보 관리현황 점검 결과 반영)

- ① 개인정보 보호책임자는 개인정보 보호를 위한 자체감사 실시 결과, 개인정보의 관리, 운영상의 문제점을 발견하거나 관련 직원이 본 계획의 내용을 위반할 때에는 시정·개선 또는 인사발령 등 필요한 조치를 취하여야 한다.
- ② 개인정보 보호책임자는 개인정보 위반사실에 대한 시정·개선 조치가 이행되지 않거나, 개인정보보호에 심각한 영향이 발생할 수 있는 우려가 되는 경우 개인정보 취급자 등에 대한 인사발령 등의 필요한 추가 조치를 취할 수 있다.

본 계획은 2022년 08월 09일부터 시행한다.